

25 May 2026

Penetration Test Report

Whitebox Security Assessment of Insights AI Staging Environment

For solarview-io

Table of contents

1. Executive summary	1.1 Confidentiality statement	3
	1.2 Report Overview	3
2. Findings	2.1 Vulnerability Distribution	4
	2.2 Master Findings Table	5
	2.3 Detailed Findings	6
Appendices	A. Scope & Methodology	35
	B. Vulnerability Coverage	36
	C. Glossary	37

1. Executive Summary

1.1 Confidentiality statement

This document is the exclusive property of **solarview-io** and **Aikido**. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires the consent of solarview-io. solarview-io may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

1.2 Report Overview

On **25 May 2026**, Aikido conducted a **white box** web application penetration test for solarview-io focused on the application(s) within the defined scope and their exposure to targeted attacks. The primary goal of this engagement was to proactively discover vulnerabilities within those scoped applications that could lead to compromise or exposure of sensitive information.

The penetration test simulated real-world attack techniques across applicable attack surfaces, including authentication, authorization, input handling, business logic, and where relevant, agentic and API-specific behaviors, to identify risks within the scoped application(s). The configured scope was limited to the following domains and associated endpoints:

- <https://staging.ensights.ai>
- <https://api.staging.ensights.ai>

The evaluation resulted in 5 high, 4 medium and 4 low findings and revealed that there are several opportunities to strengthen the cybersecurity posture of the application. The environment shows a foundational commitment to security, but targeted improvements are recommended to reduce the likelihood and impact of compromise.

Identified Improvement Points

The assessment identified several areas where access controls and authorization logic could be strengthened across the platform. A number of API endpoints appear to enforce permissions inconsistently, allowing lower-privileged users to perform actions or access data beyond their intended scope. Reviewing and aligning server-side authorization checks with the principle of least privilege across all API routes would meaningfully reduce this exposure.

Credential and token management practices present an opportunity for improvement. Sensitive values including third-party API credentials and authentication tokens were found in locations where they could be accessed by unintended parties, such as client-side bundles or misconfigured endpoints. Centralizing secrets management and auditing how credentials are distributed and referenced in the codebase would help reduce this risk.

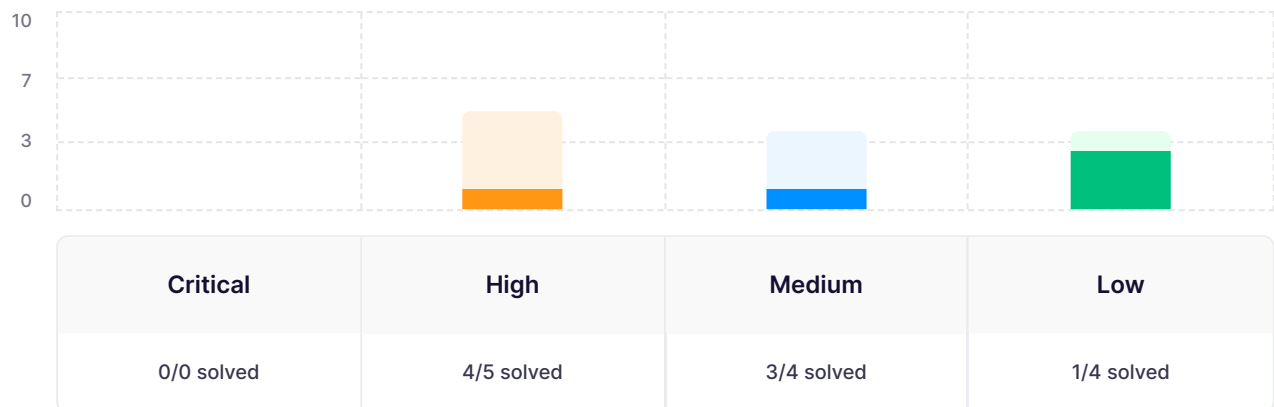
Some foundational hardening measures, such as security response headers and protections against information disclosure through error messages, are not consistently applied. Establishing baseline configuration standards for these controls across all services and environments would improve the overall security posture and reduce the amount of internal information available to potential attackers.

Conclusion

This engagement identified 13 findings that could impact the confidentiality, integrity, and availability of the application if left unaddressed. So far, 8 of 13 have been resolved and 5 remain open, reflecting active remediation and a clear commitment to the application's security posture. We recommend completing the remaining items and validating each fix through structured retesting.

2. Findings

2.1 Vulnerability Distribution



The table below outlines each identified vulnerability, categorized by severity and current remediation status. Findings highlight several critical and high-risk issues that could allow attackers to compromise application integrity, access sensitive data, or execute arbitrary code on the server.

- **High-severity issues** involve missing role-based and server-side authorization controls, cross-tenant IDOR in billing endpoints, and a leaked staging bearer token, all of which could enable privilege escalation, unauthorized data access, and cross-tenant data breaches.
- **Medium-severity issues** include hardcoded third-party API credentials exposed in a public JavaScript bundle, unauthenticated log level modification, authentication middleware bypass leaking internal network details, and missing rate limiting on staging API routes, which could lead to unauthorized system manipulation and information disclosure.
- **Low-severity issues** include unauthenticated endpoints leaking stack traces and AWS access key metadata, lack of post-quantum cryptography support, and missing or misconfigured security headers, which could expose sensitive system information and weaken long-term security posture.

2.2 Master Findings Table

ID	Title	State	Severity
PT-1	Missing role-based authorization allows viewer to create/update/delete fleets via /api/v1/fleets/fleet	Fixed	High
PT-2	Cross-tenant IDOR in billing contracts endpoint allows unauthorized read/write	Fixed	High
PT-3	Missing server-side authorization on storage write APIs allows viewer privilege escalation	Fixed	High
PT-4	Missing server-side authorization on admin statistics APIs allows viewer cross-tenant data access	Unresolved	High
PT-5	Staging bearer token leaked to non-staging domain via hardcoded WebSocket endpoint	Fixed	High
PT-6	Rate limiting and quota controls not enforced on api.staging external API routes	Fixed	Medium
PT-7	Hardcoded Third-Party API Credentials Exposed in Public JavaScript Bundle	Fixed	Medium
PT-8	Unauthenticated log level modification via POST /logger in API gateway	Fixed	Medium
PT-9	Authentication middleware bypass on unprefixed proxy routes leaks internal network details	Unresolved	Medium
PT-10	Unauthenticated /signedURL Endpoint Leaks Stack Traces and AWS Access Key Metadata	Fixed	Low
PT-11	Stack Trace Disclosure in /api/v1/assistant/chat/ask_stream via gzip Content-Encoding	Unresolved	Low
PT-12	Lack of Post-Quantum Cryptography Support	Unresolved	Low
PT-13	Missing or Misconfigured Security Headers	Unresolved	Low